

API Security Risk Analysis Report

Executive Summary

A read-only assessment was performed against a locally hosted training SaaS API.

No destructive testing occurred.

Scope

Target:

localhost:3000

Endpoints Tested:

- /
- /health
- /api/users
- /api/users/:id

Methodology:

- Endpoint discovery
 - Header inspection
 - Authentication review
 - Response analysis
-

Findings

1. Unauthenticated API Endpoint

Severity: High

Description:

The endpoint `/api/users` is accessible without authentication.

Business Impact:

User information may be accessible without verification.

Recommendation:

Require authentication and authorization.

2. Excessive Data Exposure

Severity: Medium

Description:

Internal metadata such as `role` and `internal_id` is exposed.

Recommendation:

Return only required fields.

3. Weak Access Control

Severity: High

Description:

User records are directly accessible by ID.

Recommendation:

Enforce authorization checks.